Sisain API Documentation

Base URL (dev): `http://localhost:3000` **Base URL (production):** `https://your-app.railway.app` (TBD setelah deploy)

Authentication

Sisain pakai **Supabase Auth** untuk authentication. Frontend signup/login langsung ke Supabase, dapet JWT token, terus kirim token itu ke backend di header.

Format Header

```
Authorization: Bearer <ACCESS_TOKEN>
```

Token didapat dari Supabase Auth signup/login response (`access_token` field). Token expired setelah 1 jam — pakai `refresh_token` untuk refresh atau login ulang.

Frontend Flow

```javascript
// Signup
const { data, error } = await supabase.auth.signUp({
  email: 'user@example.com',
  password: 'password123',
  options: {
    data: {
      full_name: 'John Doe',
      role: 'BUYER' // optional, default BUYER kalo gak diset
    }
  }
});

// Login
const { data, error } = await supabase.auth.signInWithPassword({
  email: 'user@example.com',
  password: 'password123'
});

// data.session.access_token → kirim ke BE
```

Trigger DB

Saat user signup, trigger `handle_new_user` otomatis bikin row di `public.users` dengan default role `BUYER`. Frontend gak perlu call BE endpoint apapun untuk register.

Standard Error Response

Semua error response punya format konsisten:

```json
{
  "error": "Error type",
  "message": "Pesan readable buat user",
  "field": "field_name (optional, untuk validation error)"
}
```

Status Codes

Code	Meaning
200	Success
201	Created
400	Validation / business rule error
401	Unauthorized (token invalid/missing/expired)
403	Forbidden (role/ownership issue)
404	Not found (resource gak ada atau RLS block)
409	Conflict (duplicate, etc)
500	Internal server error

Endpoints

1. Auth & Profile

`GET /api/auth/me`

Get current user info from JWT.

Auth: Required

Response 200:

```json
{
  "message": "Authenticated",
  "user": {
    "id": "uuid",
    "email": "user@example.com",
    "email_confirmed_at": "2026-04-27T..."
  },
  "profile": {
    "id": "uuid",
    "email": "...",
    "full_name": "John Doe",
    "role": "SELLER",
    "phone": "081234567890",
    "city": "Jakarta",
    "rating_avg": "4.50",
    "total_reviews": 12,
    "..."
  }
}
```

`GET /api/users/me`

Get full profile.

Auth: Required

Response 200: `{ profile: {...} }`

`PATCH /api/users/me`

Update profile (partial). Cuma kirim field yang mau diupdate.

Auth: Required

Body:

```json
{
  "full_name": "John Doe",        // optional
  "phone": "081234567890",        // optional
  "bio": "Saya kontraktor...",    // optional
  "address": "Jl. Sudirman No.1",
  "city": "Jakarta Selatan",
  "province": "DKI Jakarta",
  "latitude": -6.2615,
  "longitude": 106.8767,
  "avatar_url": "https://...",
  "role": "BOTH"                  // optional — BUYER/SELLER/BOTH
}
```

Business rule: Tidak bisa downgrade role dari SELLER/BOTH → BUYER kalo masih punya listing AVAILABLE/RESERVED.

Response 200: `{ message, profile: {...} }`

Use case (FE):

- BUYER klik "Jual Material" pertama kali → modal upgrade → PATCH role ke BOTH

`GET /api/users/:id`

Public profile (no email/phone exposed).

Auth: Optional

Response 200:

```json
```

```
{
  "profile": {
    "id": "uuid",
    "full_name": "...",
    "avatar_url": "...",
    "bio": "...",
    "city": "Jakarta",
    "province": "DKI Jakarta",
    "rating_avg": "4.80",
    "total_reviews": 24,
    "role": "SELLER",
    "created_at": "..."
  }
}
```

`GET /api/users/:id/reviews`

List reviews user (sebagai reviewee). Public.

Auth: Optional

Query params: `?page=1&limit=20`

Response 200:

```
json
```

```
{
  "reviews": [
    {
      "id": "uuid",
      "rating": 5,
      "comment": "Great seller, fast response",
      "created_at": "...",
      "reviewer": { "id", "full_name", "avatar_url" },
      "transaction": {
        "id": "uuid",
        "listing": { "id", "title" }
      }
    }
  ],
  "breakdown": { "1": 0, "2": 1, "3": 2, "4": 5, "5": 12 },
  "pagination": { ... }
}
```

---

2. Categories

`GET /api/categories`

All categories flat (main + sub). Public.

Response 200:

```json
{
  "count": 32,
  "categories": [
    { "id", "name", "slug", "parent_id", "co2_factor", ... }
  ]
}
```

`GET /api/categories/tree`

Nested tree (main → children). Best untuk dropdown.

Response 200:

```json
{
  "count": 5,
  "tree": [
    {
      "id", "name", "slug",
      "children": [
        { "id", "name", "slug", "co2_factor", ... }
      ]
    }
  ]
}
```

`GET /api/categories/main`

Main category only (5 items). Buat landing/filter cepat.

`GET /api/categories/:slug`

Detail by slug + children.

Response 200:

```json
{
  "id", "name", "slug", "co2_factor",
  "children": [...]
}
```

---

3. Listings

`GET /api/listings`

Browse listings (status AVAILABLE only). Public.

Query params:

Param	Type	Description
`city`	string	Filter by city (case insensitive)
`category_id`	UUID	Filter by sub-category
`category_slug`	string	Filter by main category (include subs)
`condition`	enum	GRADE_A, GRADE_B, GRADE_C, GRADE_D
`min_price`, `max_price`	number	Filter range total_price
`q`	string	Search di title + description
`sort`	enum	newest (default), oldest, price_asc, price_desc
`page`	number	default 1
`limit`	number	default 20, max 50

Response 200:

```json
{
  "data": [
    {
      "id", "title", "description", "condition",
      "quantity", "unit", "estimated_weight_kg",
      "price_per_unit", "total_price", "estimated_co2_saved",
      "city", "province", "status", "delivery_available", "view_count",
      "category": { "id", "name", "slug" },
      "seller": { "id", "full_name", "rating_avg", "city" },
      "photos": [{ "url", "is_primary", "order_index" }]
    }
  ],
  "pagination": {
    "page", "limit", "total", "total_pages", "has_next", "has_prev"
  }
}
```

Detail listing + auto increment view_count.

Response 200:

```json
{
  "id", "title", "description", "...",
  "category": {...},
  "seller": { "id", "full_name", "avatar_url", "bio", "city", "rating_avg", "total_r
  "photos": [{ "id", "url", "is_primary", "order_index" }]
}
```

`GET /api/listings/me`

My listings (semua status).

Auth: Required

Query params: `?status=AVAILABLE` (optional)

`POST /api/listings`

Create listing.

Auth: Required + role SELLER/BOTH

Body:

```json
```

```
{
  "category_id": "uuid",          // required
  "title": "string",              // required, 5-200 chars
  "description": "string",        // optional, max 2000
  "condition": "GRADE_A",         // required
  "quantity": 100,                // required, > 0
  "unit": "kg",                   // required
  "estimated_weight_kg": 100,     // required
  "price_per_unit": 12000,        // required
  "address": "string",            // required, 5-500
  "city": "string",               // required
  "province": "string",           // required
  "latitude": -6.2,               // optional
  "longitude": 106.8,             // optional
  "delivery_available": false     // optional
}
```

Note: `estimated_co2_saved` & `total_price` auto-computed di DB trigger.

Response 201: `{ message, listing }`

`PATCH /api/listings/:id`

Update listing (partial). Owner only.

Auth: Required

Body: Sama kayak POST tapi semua field optional.

`PATCH /api/listings/:id/status`

Change listing status (pause/reactivate).

Auth: Required (owner)

Body: `{ "status": "INACTIVE" }` (atau AVAILABLE)

Note: Status SOLD tidak bisa diset manual — otomatis dari transaction flow.

`DELETE /api/listings/:id`

Delete listing. Owner only.

Constraint: Tidak bisa hapus kalo ada transaksi aktif (PENDING/ACCEPTED/PAID/READY_FOR_HANDOVER) → return 409.

`POST /api/listings/:id/photos`

Upload 1+ foto (max 5 per request). Owner only.

Auth: Required

Body: `multipart/form-data`

- Field: `photos` (multiple, max 5 files, max 5MB each)
- Allowed: jpeg, png, webp

Response 201:

```json
{
  "message": "3 foto berhasil di-upload",
  "photos": [
    { "id", "url", "is_primary", "order_index" }
  ]
}
```

Note: Foto pertama dari upload pertama otomatis jadi `is_primary: true`.

`DELETE /api/listings/:id/photos/:photoId`

Delete 1 foto.

Auth: Required (owner)

Note: Kalo yang dihapus primary, foto berikutnya by order_index otomatis jadi primary.

---

4. Conversations & Messages

`POST /api/conversations`

Start atau resume conversation di sebuah listing. Bikin baru kalo belum ada, append message kalo udah.

Auth: Required

Body:

```json
{
  "listing_id": "uuid",
  "message": "string (1-500 chars)"
}
```

Business rules:

- Tidak bisa chat listing sendiri
- Listing harus AVAILABLE atau RESERVED

Response 201:

```json
{
  "message": "...",
  "conversation": { "id", "listing_id", "buyer_id", "seller_id", "listing_title" },
  "first_message": { "id", "content", "sender_id", "created_at" }
}
```

`GET /api/conversations`

List my conversations (sebagai buyer ATAU seller). Sorted by last_message_at desc.

Auth: Required

Response 200:

```json
```

```
{
  "count": 5,
  "conversations": [
    {
      "id": "uuid",
      "listing": { "id", "title", "status", "primary_photo" },
      "other_user": { "id", "full_name", "avatar_url" },
      "my_role": "BUYER",
      "last_message": { "content", "sender_id", "read_at", "created_at" },
      "unread_count": 3,
      "last_message_at": "...",
      "created_at": "..."
    }
  ]
}
```

`GET /api/conversations/:id/messages`

Get message history (newest first). Participant only.

Auth: Required

Query params: `?page=1&limit=50`

Response 200:

```json
{
  "messages": [
    {
      "id", "conversation_id", "sender_id", "content", "read_at", "created_at",
      "sender": { "id", "full_name", "avatar_url" }
    }
  ],
  "pagination": { ... }
}
```

`POST /api/conversations/:id/messages`

Kirim message ke conversation existing.

Auth: Required (participant)

Body: `{ "content": "string (1-500 chars)" }`

`PATCH /api/conversations/:id/read`

Mark all unread messages dari lawan bicara sebagai read.

Auth: Required (participant)

Response 200: `{ message, updated_count: 3 }`

---

5. Transactions

State Machine

```
PENDING → ACCEPTED → PAID → READY_FOR_HANDOVER → COMPLETED
   ↓         ↓
 cancel    cancel (or seller reject if still PENDING)
   ↓         ↓
        CANCELLED
```

Transition	Endpoint	Who
Create (→ PENDING)	`POST /api/transactions`	BUYER
→ ACCEPTED	`PATCH /api/transactions/:id/accept`	SELLER
→ REJECTED	`PATCH /api/transactions/:id/reject`	SELLER (only PENDING)
→ CANCELLED	`PATCH /api/transactions/:id/cancel`	participant (PENDING/ACCEPTED)
→ PAID	`POST /api/transactions/:id/payment` (multipart)	BUYER
→ READY_FOR_HANDOVER	`PATCH /api/transactions/:id/ready`	SELLER
→ COMPLETED	`PATCH /api/transactions/:id/complete`	BUYER

`POST /api/transactions`

Create new order.

Auth: Required

Body:

```json
{
  "listing_id": "uuid",            // required
  "quantity": 50,                  // required, > 0, ≤ stock
  "delivery_method": "DELIVERY",   // SELF_PICKUP atau DELIVERY
  "delivery_address": "Jl...",     // required jika DELIVERY
  "buyer_message": "..."           // optional
}
```

Side effect:

- Reduce listing.quantity oleh order quantity
- Kalo full reserved (qty habis) → listing.status = RESERVED

Response 201:

```json
{
  "message": "Order berhasil dibuat. Tunggu konfirmasi seller.",
  "transaction": {
    "id", "listing_id", "buyer_id", "seller_id",
    "quantity", "total_price", "total_weight_kg",
    "delivery_method", "delivery_address",
    "status": "PENDING", "buyer_message",
    "listing_title", "listing_unit"
  }
}
```

`GET /api/transactions`

My transactions (buyer ATAU seller).

Auth: Required

Query params:

Param	Description
`role`	BUYER / SELLER / ALL (default ALL)
`status`	filter by transaction status
`page`, `limit`	pagination

Response 200:

```json
```

```
{
  "data": [
    {
      "id", "status", "quantity", "total_price",
      "total_weight_kg", "co2_saved",
      "delivery_method", "delivery_address",
      "payment_proof_url",
      "created_at", "accepted_at", "paid_at", "completed_at",
      "my_role": "BUYER",
      "primary_photo": "https://...",
      "listing": {...}, "buyer": {...}, "seller": {...}
    }
  ],
  "pagination": {...}
}
```

`GET /api/transactions/:id`

Transaction detail. Participant only.

`PATCH /api/transactions/:id/accept`

Seller accept order.

Body: kosong

`PATCH /api/transactions/:id/reject`

Seller reject (only PENDING). Restores stock.

Body: `{ "reason": "..." }` (optional)

`PATCH /api/transactions/:id/cancel`

Cancel (PENDING/ACCEPTED only). Buyer or seller. Restores stock.

Body: `{ "reason": "..." }` (optional)

`POST /api/transactions/:id/payment`

Buyer upload payment proof.

Auth: Required (buyer)

Body: `multipart/form-data`

- Field: `payment_proof` (single file)
- Allowed: jpeg, png, webp, pdf
- Max: 5 MB

Response 200:

```json
{
  "message": "...",
  "transaction": {
    "status": "PAID",
    "paid_at": "...",
    "payment_proof_url": "https://...signed-url..."
  }
}
```

Note: `payment_proof_url` signed URL valid 7 hari (private bucket).

`PATCH /api/transactions/:id/ready`

Seller mark ready for handover.

Body: kosong

`PATCH /api/transactions/:id/complete`

Buyer confirm completed.

Body: kosong

Side effects (auto via DB trigger):

- `co2_saved` & `total_weight_kg` snapshotted
- `completed_at` set

- Listing dengan status RESERVED → SOLD

Response 200:

```json
{
  "message": "Transaction completed! Thanks for using Sisain 🌱",
  "transaction": {...},
  "impact": {
    "co2_saved_kg": 925,
    "weight_diverted_kg": 500
  }
}
```

---

6. Reviews

`POST /api/reviews`

Create review.

Auth: Required

Body:

```json
{
  "transaction_id": "uuid",
  "rating": 5,                    // 1-5 integer
  "comment": "string"             // optional, max 500
}
```

Business rules:

- Transaction harus COMPLETED
- Reviewer harus participant
- Reviewee auto-determined (lawan bicara)
- 1 reviewer hanya bisa review 1 kali per transaction

Side effect: DB trigger auto-update `users.rating_avg` & `total_reviews`.

`GET /api/reviews/transaction/:transactionId`

Get reviews dari 1 transaksi (max 2 — buyer & seller).

---

7. Impact Dashboard

`GET /api/impact/platform`

Public platform-wide stats.

Response 200:

```json
{
  "stats": {
    "total_users": 250,
    "total_listings": 480,
    "total_transactions": 120,
    "total_kg_saved": 45000,
    "total_co2_saved": 12500,
    "total_gmv": 850000000
  },
  "equivalents": {
    "car_km_avoided": 57500,
    "trees_planted_equivalent": 595
  }
}
```

`GET /api/impact/me`

Personal impact dashboard.

Auth: Required

Response 200:

```json
```

```
{
  "impact": {
    "user_id", "full_name",
    "sales_count", "purchase_count",
    "kg_sold", "kg_bought",
    "total_co2_saved",
    "total_earned", "total_spent"
  },
  "equivalents": { "car_km_avoided", "trees_planted_equivalent" }
}
```

`GET /api/impact/leaderboard`

Top contributors by CO2 saved. Public.

Query: `?limit=10`

Response 200:

```json
{
  "leaderboard": [
    {
      "rank": 1,
      "user_id": "uuid",
      "full_name": "...",
      "total_co2_saved": 5000,
      "transactions_count": 25
    }
  ],
  "count": 10
}
```

Test Accounts (Seed Data)

Seller accounts (password: `password123`):

Email	Name	Location
mustaqim@test.com	(TBD)	(TBD)
supardi@test.com	(TBD)	(TBD)
johnson@test.com	(TBD)	(TBD)
agus@test.com	(TBD)	(TBD)
jonny@test.com	(TBD)	(TBD)

Test buyer:

- buyer@test.com / password123

Notes for Frontend

1. **Token expiry:** JWT valid 1 jam. FE harus handle refresh token via Supabase client.
2. **Image URLs:** `listing-photos` bucket public — direct URL bisa dipake. `payment-proofs` private — signed URL valid 7 hari.
3. **Pagination:** Default 20 per page, max 50. Response selalu kasih `has_next`, `has_prev`, `total_pages`.
4. **RLS:** Akses ke chat/transactions otomatis dilindungi RLS — non-participant dapet 404 (bukan 403, untuk security).
5. **Real-time:** Untuk chat & transaction updates, FE bisa polling tiap 10-30 detik atau pake Supabase Realtime subscriptions (optional, advanced).

Common Frontend Patterns

Cek apakah listing punya foto

```javascript
const primaryPhoto = listing.photos.find(p => p.is_primary)?.url
  ?? listing.photos[0]?.url
  ?? '/placeholder.png';
```

Format Rupiah

```javascript
const formatRp = (n) => `Rp ${Number(n).toLocaleString('id-ID')}`;
// formatRp(150000) → "Rp 150.000"
```

Display impact di profile

```jsx
<p>Kamu sudah menghemat <strong>{impact.total_co2_saved} kg CO₂e</strong></p>
<p className="text-sm text-gray-500">
  Setara dengan menghindari berkendara {equivalents.car_km_avoided} km 🚗
</p>
```